

CYBER SECURITY

Project 3: Phishing Awareness Analysis

Industrial Training Kit | Batch 2026 | DecodeLabs

Submitted by: Kuyilini Thiyaharajah

Date: 31/05/2026

Role: Cybersecurity Analyst (Intern)

Table of Contents

- 1. Introduction..... 3
- 2. Understanding Phishing Attacks..... 3
 - 2.1 Definition 3
 - 2.2 Types of Phishing 3
- 3. Sample Phishing Message Analysis..... 4
 - Sample 1 — Fake Microsoft Security Alert (Mass Phishing)..... 4
 - Sample 2 — CEO Wire Transfer Request (Whaling / BEC) 5
 - Sample 3 — Fake IT Password Reset (Spear Phishing) 6
- 4. Master Red Flag Checklist..... 7
- 5. Phishing Triage Toolkit 8
 - 5.1 Decision Framework..... 8
 - 5.2 The Golden Rule: Pause — Verify — Report 8
 - 5.3 URL Inspection Procedure..... 8
- 6. Conclusion 9

1. Introduction

Phishing remains the single most prevalent attack vector in modern cybersecurity. According to industry simulations, 80% of security breaches involve some form of phishing, and it takes an average of just 82 seconds from the launch of a phishing campaign for an attacker to receive their first click. Technical firewalls and spam filters alone cannot compensate for human error — this is why building a "Human Firewall" through awareness training is critical.

This report fulfils the requirements of Project 3 of the DecodeLabs Cyber Security Industrial Training Kit. The objective is to analyze sample phishing messages, identify indicators of compromise (IoCs), explain the psychological manipulation techniques employed, and deliver a reusable Phishing Triage Toolkit for non-expert users.

2. Understanding Phishing Attacks

2.1 Definition

Phishing is a form of social engineering attack in which a threat actor impersonates a trusted entity to deceive the recipient into revealing credentials, transferring funds, or installing malware. Unlike technical exploits, phishing targets human psychology — the weakest link in any security chain.

2.2 Types of Phishing

- **Mass Phishing** — Generic lures mimicking well-known brands (Amazon, PayPal, Google). High volume, low personalization, roughly 1% engagement rate.
- **Spear Phishing** — Highly targeted attacks using OSINT (e.g., LinkedIn data) to reference specific project names, colleagues, or internal jargon. Much higher success rate.
- **Whaling** — Targets executives and C-suite members to execute high-value wire transfers (Business Email Compromise) or extract M&A documents.
- **Smishing** — Phishing delivered via SMS, often disguised as package delivery or bank alerts.
- **Vishing** — Voice phishing using caller ID spoofing to impersonate IT support or government agencies.
- **Quishing** — Malicious QR codes placed on physical or digital surfaces that redirect users to spoofed domains, bypassing desktop URL filters.

3. Sample Phishing Message Analysis

Three representative phishing messages have been selected and analyzed below. Each sample is dissected for red flags, suspicious elements, and the psychological manipulation technique being exploited.

Sample 1 — Fake Microsoft Security Alert (Mass Phishing)

From:	Microsoft Support <support@logins-updates.com>
Subject:	URGENT: Your Microsoft Account Has Been Compromised — Verify Now
Body:	Dear User, We have detected unusual sign-in activity on your account. Your account will be permanently suspended within 24 hours unless you verify your identity immediately. Click here to verify: http://microsft-secure.logins-updates.com/verify

Red Flags Identified

- **Sender-domain mismatch:** Display name is "Microsoft Support" but the actual address is support@logins-updates.com — not a Microsoft domain.
- **Typosquatting:** The link uses microsft-secure.logins-updates.com — "microsft" is a deliberate misspelling of Microsoft, and the true root domain is logins-updates.com (malicious).
- **Subdomain trap:** Reading right-to-left: the root domain is logins-updates.com, not microsoft.com. The legitimate-looking prefix is just a subdomain.
- **Urgency language:** "24 hours", "permanently suspended", "immediately" — designed to trigger fight-or-flight and override rational thinking.
- **Generic salutation:** "Dear User" — legitimate services address users by name. Mass phishing cannot personalize at scale.

Psychological trigger used:

FEAR — The threat of permanent account loss creates acute anxiety, forcing the user to act before thinking critically.

Verdict:

MALICIOUS — Block domain logins-updates.com and escalate to IT Security immediately.

Sample 2 — CEO Wire Transfer Request (Whaling / BEC)

From:	CEO - STRICTLY CONFIDENTIAL <ceo.urgent@executive-update.com>
Subject:	IMMEDIATE ACTION REQUIRED: Transfer Authorization
Body:	I need you to process the attached wire transfer instruction IMMEDIATELY. This is STRICTLY CONFIDENTIAL. Do not discuss with anyone. Bypass standard procedure. Thank you.

Red Flags Identified

- **Authority impersonation:** Claims to be the CEO — a classic whaling tactic designed to demand unquestioned compliance.
- **Spoofed domain:** The email originates from executive-update.com, not the company's own domain. The "CEO" prefix in the display name is cosmetic.
- **Secrecy instruction:** "Do not discuss with anyone" — explicitly instructs the target to bypass the one action (verification) that would expose the fraud.
- **Procedure bypass request:** "Bypass standard procedure" is a direct command to skip the financial controls that would detect the fraud.
- **Urgency + authority combined:** Combining pressure from a perceived authority figure with extreme time pressure is the hallmark of Business Email Compromise (BEC).

Psychological trigger used:

AUTHORITY + URGENCY — The combination of a high-ranking figure and a time-pressured command is among the most effective and costly phishing tactics, responsible for billions in annual losses.

Verdict:

MALICIOUS — Do not process. Block domain executive-update.com. Report to IT Security and Finance immediately. Preserve the email as evidence.

Sample 3 — Fake IT Password Reset (Spear Phishing)

From:	IT Security <it-security@company-helpdesk.net>
Subject:	Mandatory: Your password expires in 24 hours
Body:	Dear Employee, Our records show your corporate password will expire in 24 hours. To avoid losing access to all systems, click the link below to reset your password now. Reset Password: http://company.com.password-reset-portal.net/reset

Red Flags Identified

- **Combosquatting domain:** The link uses company.com.password-reset-portal.net — company.com appears legitimate but is just a subdomain. The true root is password-reset-portal.net (malicious).
- **Credential harvesting:** The link leads to a fake login portal designed to capture your username and password.
- **Urgency language:** "24 hours", "avoid losing access" — manufactured scarcity creates panic.
- **Sender domain mismatch:** Legitimate corporate IT never uses an external domain like company-helpdesk.net for internal security alerts.
- **Generic salutation:** "Dear Employee" — real internal IT systems use your actual name.

Psychological trigger used:

URGENCY + FEAR OF LOSS — The prospect of losing access to all work systems in 24 hours is enough to make most users click without inspecting the link.

Verdict:

MALICIOUS — Block domain password-reset-portal.net. Report to IT Security. Never click credential-reset links in emails — always navigate to the SSO portal directly.

4. Master Red Flag Checklist

The following checklist is designed for non-expert users to evaluate any incoming email or message. Check each item systematically before taking any action.

#	Red Flag	What to Look For
1	Sender-domain mismatch	Display name says trusted brand but actual email address is from an unrelated domain
2	Typosquatting / lookalike domain	amaz0n.com, paypal.com, yourcompany-secure-login.com
3	Subdomain trap	Read URL right-to-left — true root domain is at the far right (e.g., login-update.com)
4	Urgency language	"Account locked in 30 minutes", "Immediate action required" — triggers panic to bypass logic
5	Authority impersonation	Fake CEO, IT Dept, law enforcement demanding unquestioned compliance
6	Request for sensitive info	Unexpected prompts for passwords, MFA codes, or payment details via email
7	Dangerous attachments	Files ending in .iso, .js, .scr, .exe, or HTML smuggling links
8	Fake forwarded chains	FW: prefix with pasted headers and odd timestamps from conversations you were never in
9	Unsolicited QR codes	QR code in email demanding a scan to "secure your account" — bypasses desktop URL filters
10	MFA fatigue	Multiple unprompted authenticator push notifications designed to wear the user down
11	Secrecy instructions	"Do not discuss with anyone", "Bypass standard procedure" — hallmarks of BEC attacks

5. Phishing Triage Toolkit

5.1 Decision Framework

Every suspicious email must end in a definitive verdict. Use the three-tier framework below to classify and respond:

Verdict	Criteria	Action
SAFE	Sender verified, no suspicious links, no urgency pressure, no credential request	Close / Delete — no further action needed
SUSPICIOUS	Minor domain anomaly, unusual urgency, unexpected attachment, unverified sender	Warn user — do NOT click links. Verify via phone call to known directory number.
MALICIOUS	Clear impersonation, credential harvesting links, spoofed domain, dangerous attachment	Block domain & escalate to IT Security immediately. Do NOT delete — preserve for forensics.

5.2 The Golden Rule: Pause — Verify — Report

- **PAUSE:** Recognize the cognitive trigger (Urgency, Fear, Authority). Stop interacting with the message. Apply the Five-Minute Rule — wait before acting.
- **VERIFY:** Confirm the request through a secondary, out-of-band channel. If the request came via email, call the sender directly using a known, verified number — not a number from the email itself.
- **REPORT:** Use your organization's internal reporting tool. Do NOT simply delete the email — reporting allows the security team to purge the threat from all other inboxes and block the domain organization-wide.

5.3 URL Inspection Procedure

- Read URLs from right to left — the true root domain is always just before the first single slash (/).
- Check for typosquatting: amaz0n, microsoft, paypal — subtle character substitutions.
- Check for homoglyph attacks: characters from other alphabets that look identical (Cyrillic 'a' vs Latin 'a').
- Check for combosquatting: yourcompany-secure-login.com, yourcompany.password-reset.net.
- Hover over links (without clicking) to preview the actual URL in your email client's status bar.
- When in doubt, navigate directly — type the website address manually into your browser instead of clicking any link.

6. Conclusion

This analysis has demonstrated that modern phishing attacks are sophisticated, psychologically engineered threats that cannot be reliably blocked by technical controls alone. The three samples analyzed cover the most common and dangerous attack categories: mass credential harvesting, Business Email Compromise (BEC), and internal impersonation.

The key defensive skills developed through this project are: the ability to dissect sender addresses and URLs for domain anomalies, recognition of the four primary cognitive triggers (Authority, Urgency, Curiosity, Fear/Greed), and systematic triage using the Pause-Verify-Report framework.

By internalizing these skills, every employee becomes an active layer of defense — a Human Firewall that complements technical controls and closes the gap that attackers exploit.

— End of Report —